

Unsupervised Detection of Attack Surface Drift

CS 4412 Project Proposal

Alec Sundby
CS4412 ASM Data Mining
Kennesaw State University
asundby@student.kennesaw.edu

This proposal outlines my project to apply unsupervised data mining to the field of Attack Surface Management (ASM). I am using the LANL Cyber Security dataset to find patterns of software drift and Shadow IT that standard security tools often miss. I am going to use PCA for dimensionality reduction, DBSCAN for clustering, and Isolation Forests to find statistical outliers in network telemetry. These three tactics work together as a pipeline. PCA acts as the first layer to compress the high-dimensional logs, which makes it feasible for DBSCAN to identify behavioral clusters. The Isolation Forest then processes the data to rank anomalies. This combined approach will allow me to identify outliers more accurately compared to using a single algorithm on the raw, high-dimensional data.

I. INTRODUCTION

It is a known fact that enterprise networks are constantly changing. Therefore, software configurations drift away from secure baselines because of system updates, user behavior, and unauthorized changes known as Shadow IT. Most security tools look for signatures of known attacks, which means that they miss new or unknown configuration states.

My approach will initially consist of looking at unlabeled data to see if natural formations of groups can be dictated based on their behavior. If a device or user drifts away from these groups, it could be noted as a security risk. My analysis will focus on enterprise-scale telemetry to try to determine the difference between normal administrative work and anomalies that need to be investigated.

II. DATASET DESCRIPTION

A. Name and Source

The dataset for this project is the LANL Cyber Security Dataset from Los Alamos National Laboratory. It contains real authentication and network activity from the Los Alamos National Laboratory enterprise network.

B. Size and Scope

The dataset has millions of log entries, which is too large for most hardware to handle. Therefore, I will use a sampled subset of 50,000 to 100,000 records to keep it feasible while still having enough data to see patterns.

- Target Size: Approximately 50,000 to 100,000 records.
- Content: Authentication events and network connection logs.

C. Key Attributes

I will extract the following features for the discovery process:

- Timestamps: To find time-series patterns in system usage.
- Host Relationships: To map which machines talk to each other.
- Authentication Outcomes: To find success and failure patterns.
- User IDs: To track behavior across different devices.

III. DISCOVERY QUESTIONS

This project predominantly focuses on discovery questions to reveal the structure of the data rather than predicting specific labels.

A. DQ1: Behavioral Clustering

Are there natural clusters of system behavior that separate normal operations from irregular usage patterns? If I can find these clusters, I can identify drift without needing a dataset that is already labeled with attacks.

B. DQ2: Concept Drift

Which entities show significant changes in their behavior over time? This will help find systems or users that might be using unauthorized software or have compromised credentials.

IV. PLANNED TECHNIQUES

The analysis follows a three-stage pipeline for unsupervised learning.

A. Dimensionality Reduction (PCA)

PCA will be used to compress high-dimensional data into a smaller space. This helps to visualize behavior and see if drift shows up as movement away from the dense regions where normal activity occurs.

B. Clustering (DBSCAN)

DBSCAN will be used to find regions of normal behavior. I chose this because I do not need to tell it how many clusters to find. Points that do not relate to these regions are likely to represent drifting behavior.

C. Anomaly Detection (Isolation Forest)

Isolation Forests will be used to give anomaly scores to different events. If an event is easy to isolate with few splits, it gets a higher score. This enables the ability to rank potential drift cases for further investigation.

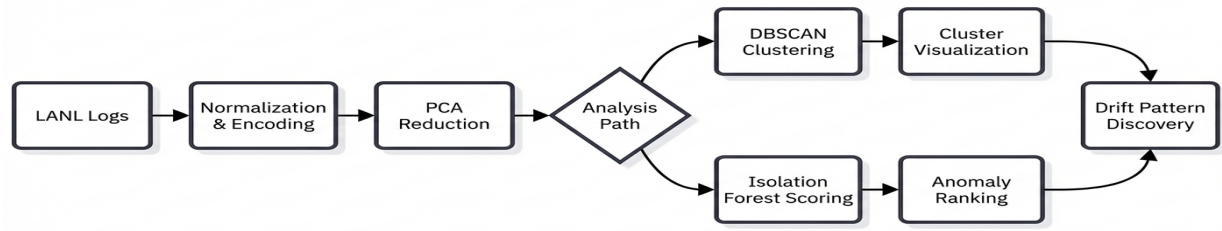


Fig. 1. Data Mining Pipeline for Pattern Discovery.

V. EVALUATION AND VALIDATION

Evaluating unsupervised models is challenging due to the lack of direction/definition of an unwarranted connection. I will use the following metrics to validate the discoveries:

A. Internal Evaluation

I will utilize the Silhouette Coefficient and Davies-Bouldin Index to assess the cluster's quality, which I will then relate to the variables that I plan to extract from the datasets. A high Silhouette score will indicate the behavioral clusters as being well-defined and distinct, which suggests that the baseline is normal. Additionally, I will look for a low Davies-Bouldin Index because that will indicate a favorable ratio of within-cluster scatter to between-cluster separation. These metrics will be applied throughout the tuning phase as I utilize DBSCAN's epsilon and min_samples parameters to establish a baseline understanding of the network activity. The purpose of using both metrics is to objectively determine the most applicable configuration that will return the most distinct behavioral groups before I delve into the anomaly detection itself. The Silhouette score is how I will learn to understand the baseline behaviors, while the Davies-Bouldin score will allow for the visualization of the distance/distinction of data clusters and Shadow IT points.

B. Anomaly Verification

The anomalies that are identified by the Isolation Forest will be utilized for a qualitative observation. I will take these suspected anomalies and cross-reference high scoring outliers with the original LANL event logs. From this point I will be able to see if they correspond to known administrative patterns or harmless irregularities.

C. Conclusion

The aim of this project is to ultimately create and demonstrate the ability to delimit behavioral analysis when regarding Attack Surface Drift. This will be identified through statistical deviations in the network telemetry by implementing a pipeline of PCA, DBSCAN, and Isolation Forests.

VI. PRELIMINARY TIMELINE

- Milestone 2: Download the data, sample it, and handle the feature encoding and normalization.
- Milestone 3: Apply PCA and DBSCAN, tune the parameters, and generate the anomaly scores.
- Milestone 4: Look at the high-scoring anomalies and see if the patterns actually represent meaningful drift.

VII. GITHUB REPOSITORY

Repository Name: `cs4412-asm-mining` <https://github.com/asundby6/cs4412-asm-mining>

REFERENCES

- [1] M. Turcotte, A. Kent, and C. Hash, "Unified Host and Network Data Set," in *Data Science for Cyber-Security*, World Scientific, Nov. 2018, pp. 1–22. [Online]. Available: <https://csr.lanl.gov/data/2017/>